

Manual 43 — Implementación Controlada de Seguridad y Privacidad en la Nube ISO/IEC 27017 y 27018

****Línea base:**** ISO/IEC 27017:2026 Edición 2 e ISO/IEC 27018:2025 Edición 3. ****Límite de copyright:**** orientación original del proyecto; no reproduce texto protegido ni constituye traducción autorizada de ISO.

Chapter 01 — Fuentes y límite de copyright

Mantenga ediciones, acceso autorizado, resúmenes propios, restricciones, citas y verificación previa a liberación.

Chapter 02 — Alcance y relaciones entre normas

Delimite 27017, 27018 y sus relaciones con 27001, 27002, 27701, contratos y legislación.

Chapter 03 — Modelos de servicio en nube

Clasifique IaaS, PaaS, SaaS y servicios administrados; asigne responsabilidades por modelo.

Chapter 04 — Responsabilidad cliente-proveedor

Defina propietarios de seguridad, privacidad, arquitectura, incidentes, proveedores y evidencia.

Chapter 05 — Responsabilidad compartida

Mantenga matrices por servicio con propiedad, configuración, evidencia, dependencias y excepciones.

Chapter 06 — Gobierno de seguridad de la información

Integre riesgos de nube en políticas, evaluación, tratamiento, cambios, aseguramiento y revisión gerencial.

Chapter 07 — Activos y configuración

Inventaríe cuentas, cargas, datos, imágenes, secretos, regiones, dependencias y configuraciones aprobadas.

Chapter 08 — Identidad y acceso

Gobierne federación, ciclo de cuentas, autenticación, autorización, identidades de servicio y revisiones.

Chapter 09 — Administración privilegiada

Aplique mínimo privilegio, MFA, elevación temporal, registros, cuentas de emergencia y segregación.

Chapter 10 — Entornos virtuales y compartidos

Evalúe aislamiento, multitenencia, contenedores, hipervisores, servicios compartidos y evidencia del proveedor.

Chapter 11 — Operaciones administrativas

Controle mantenimiento, soporte, automatización, consolas, cambios urgentes y acceso remoto.

Chapter 12 — Arquitectura de red y nube

Diseñe segmentación, entradas/salidas, conectividad privada, endpoints, DNS, firewalls y revisión de exposición.

Chapter 13 — Registro y monitoreo

Defina logs, telemetría, alertas, retención, sincronización, integridad, centralización e investigación.

Chapter 14 — Criptografía y claves

Defina cifrado, propiedad de claves, rotación, respaldo, HSM, secretos, revocación y evidencia.

Chapter 15 — Vulnerabilidades y configuración

Gestione imágenes, hosts, contenedores, dependencias, parches, postura, SLAs y excepciones.

Chapter 16 — Gestión de incidentes

Defina detección, triage, evidencia, comunicaciones, contención, privacidad, notificación y lecciones aprendidas.

Chapter 17 — Resiliencia y disponibilidad

Establezca objetivos, zonas/regiones, respaldos, recuperación, capacidad, continuidad y pruebas.

Chapter 18 — Portabilidad e interoperabilidad

Planifique formatos, interfaces, migración, extracción, dependencias, lock-in, pruebas y salida.

Chapter 19 — Eliminación y devolución segura

Controle devolución, eliminación, borrado criptográfico, copias residuales, backups y evidencia del proveedor.

Chapter 20 — Proveedores y subprocesadores

Inventaríe terceros, contratos, ubicaciones, cambios, incidentes, auditoría, remediación y terminación.

Chapter 21 — Alcance de procesador de PII en nube pública

Determine roles y documente instrucciones, categorías, finalidades y capas jurídicas sin convertir ISO en ley.

Chapter 22 — Instrucciones del cliente y límites de finalidad

Documente procesamiento autorizado, usos prohibidos, cambios, soporte, retención y eliminación.

Chapter 23 — Divulgación y transparencia

Mantenga información sobre proveedor, subprocesadores, ubicaciones, capacidades, cambios y riesgos materiales.

Chapter 24 — Soporte a brechas

Defina detección, comunicación, evidencia, apoyo a evaluación/notificación, coordinación y remediación.

Chapter 25 — Ubicación y transferencias de datos

Rastree almacenamiento, replicación, soporte, acceso remoto, transferencias y decisiones jurisdiccionales.

Chapter 26 — Controles contractuales

Traduzca responsabilidades a contratos, DPA, SLA, incidentes, auditoría, subprocesadores, eliminación y salida.

Chapter 27 — Evidencia y auditabilidad

Defina evidencia de responsabilidades, configuraciones, acceso, logs, incidentes, eliminación, resiliencia y privacidad.

Chapter 28 — Tratamiento de riesgos

Evalúe amenazas de nube, fallas compartidas, concentración, exposición, resiliencia y restricciones de salida.

Chapter 29 — Crosswalks 27001, 27002 y 27701

Use crosswalks propios con supuestos, no equivalencia, diferencias de edición y mapeos de evidencia.

Chapter 30 — Métricas y límites de aseguramiento

Mida postura, privilegios, incidentes, proveedores, recuperación, eliminación, excepciones y cobertura.

Chapter 31 — Localización, procedencia y copyright

Congele EN/es-419/pt-BR, preserve aviso de traducción no autorizada y vincule candidatos a SHA-256.

Chapter 32 — Reverificación de edición y liberación

Revalide versiones ISO, dependencias, predecesor 42, identidad exacta, QA limpia y registros antes de publicar.